

CUADERNO DE TRABAJO: GQM + PRAGMATIC IMPLEMENTACIÓN

Plantilla Operativa para CISOs e Implementadores

Versión: 1.0

Fecha: Enero 21, 2026

Formato: Guía paso-a-paso con templates descargables

PARTE I: PLANTILLA GQM PARA TU ORGANIZACIÓN

Paso 1: Define tu GOAL (Objetivo Estratégico)

GOAL es una declaración clara de QUÉ quieres lograr en X meses.

Formato:

GOAL: [Verbo acción] [Objeto] [para lograr] [Beneficio]

Ejemplo:

"Detectar 95% de vulnerabilidades de código ANTES de producción para reducir riesgo de breach por código inseguro"

Tu GOAL:

GOAL : _____

Contexto (llenar):

- Timeline: meses
- **Métrica de éxito:**
- Presupuesto máximo: €
- **Stakeholders clave:**

Paso 2: Deriv QUESTIONS (Preguntas Operacionales)

Para cada GOAL, formula 3-5 QUESTIONS que desglosen cómo sabrás que lograste el goal.

Formato:

Q1: ¿[Criterio] de [Objeto] está en [Nivel]?

Q2: ¿[Métrica] alcanzó [Target]?

Q3: ¿[Actividad] se ejecuta [Frecuencia]?

Ejemplo:

Q1: ¿El % de código bajo SAST está en 95%+?

Q2: ¿El MTTD de vulnerabilidad crítica alcanzó <2 días?

Q3: ¿Los checkpoints de seguridad se ejecutan en 100% de builds?

Tus QUESTIONS:

Q1: _____
Q2: _____
Q3: _____
Q4: _____
Q5: _____

Paso 3: Define METRICS (Métricas Técnicas)

Para cada QUESTION, define METRICS que sean **medibles y cuantificables**.

Formato:

Para Q: "[Pregunta]?"

Métrica M1: [Indicador] = [Fórmula] (Unidad)

Métrica M2: [Indicador] = [Fórmula] (Unidad)

Ejemplo:

Para Q1: "¿El % de código bajo SAST está en 95%+?"

Métrica M1: SAST Coverage = (Líneas escaneadas / Líneas totales) × 100 (%)

Métrica M2: SAST Tools Deployed = # herramientas SAST activas (unidades)

Para Q2: "¿El MTTR de vulnerabilidad crítica alcanzó <2 días?"

Métrica M1: MTTR Crítico = (Fecha detección - Fecha alerta) (horas)

Métrica M2: % detectadas internamente = (# internos / # total) × 100 (%)

Tus METRICS:

Para Q1:

M1.1: _____ = _____ (unidad)

M1.2: _____ = _____ (unidad)

Para Q2:

M2.1: _____ = _____ (unidad)

M2.2: _____ = _____ (unidad)

Para Q3:

M3.1: _____ = _____ (unidad)

M3.2: _____ = _____ (unidad)

PARTE II: PLANTILLA PRAGMATIC PARA TUS MÉTRICAS

Paso 1: Listar Métricas Candidatas

De Parte I, lista todas tus métricas. Para cada una, evaluarás contra 9 criterios PRAGMATIC.

Tus Métricas:

[] M1: _____
[] M2: _____
[] M3: _____
[] M4: _____
[] M5: _____

Paso 2: Evaluar Cada Métrica contra PRAGMATIC

Para cada métrica, califica 0-100 en cada criterio (donde 0=no cumple, 100=cumple perfectamente).

PLANTILLA DE EVALUACIÓN:

Métrica: [Nombre]

Criterio	Preguntas	Tu Score (0-100)	Justificación
P Predictive	¿Predice riesgo futuro? ¿Permite pronóstico?	—	—
R Relevant	¿Es relevante a GOAL? ¿Alineada con negocio?	—	—
A Actionable	¿Lleva a acción específica? ¿Qué se hace si score baja?	—	—
G Genuine	¿Se basa en datos observados? ¿Es observable?	—	—
M Meaningful	¿Tiene significado operacional? ¿Es interpretable?	—	—
A Accurate	¿Es medible con precisión? ¿Hay definición clara?	—	—
T Timely	¿Se obtiene en tiempo útil? ¿Frecuencia adecuada?	—	—
I Independent	¿Es independiente o correlaciona con otras?	—	—
C Cost	¿Es económicamente viable medir? ¿Bajo costo?	—	—
PRAGMATIC SCORE	Promedio de 9 criterios	—	✓ / ⚠ / ☒

Paso 3: Interpretar Score PRAGMATIC

- **GREEN (85-100):** Adoptar inmediatamente
Ej: "SAST Coverage % = 91 PRAGMATIC"
Acción: Implementar esta métrica en Q1
- **YELLOW (70-84):** Evaluar y adoptar con cuidado
Ej: "Threat Modeling = 81 PRAGMATIC"
Acción: Implementar en Q2-Q3 después de validar ROI
- **RED (<70):** Considerar alternativa
Ej: "Crisis Simulation = 66 PRAGMATIC"
Acción: Rechazar o reemplazar por métrica más pragmática

PARTE III: MATRIZ DE DECISIÓN GQM + PRAGMATIC

Template: Consolidar TODO

GOAL : _____

QUESTION	METRIC	Data Source	Frecuencia	PRAGMATIC	Prioridad	Trimestre
Q1	M1.1	_____	Mensual	___	☐ P1	Q1 2026
Q1	M1.2	_____	Trimestral	___	☐ P2	Q2 2026
Q2	M2.1	_____	Real-time	___	☐ P1	Q1 2026
Q2	M2.2	_____	Semanal	___	☐ P3	Q3 2026
Q3	M3.1	_____	Mensual	___	☐ P1	Q1 2026

PARTE IV: ROADMAP DE IMPLEMENTACIÓN

FASE 1: Seleccionar PRAGMATIC ≥ 85 (Quick Wins)

Instrucciones:

1. De tu matriz GQM + PRAGMATIC, selecciona métricas con score ≥ 85
2. Son tus "Quick Wins" para Q1
3. Presupuesto típico: €15k-€25k
4. Plazo: 90 días
5. Impacto: +8-15 puntos en score BSIMM

Mis Quick Wins (PRAGMATIC ≥ 85):

- ☐ Métrica 1: _____ (Score: ____)
- ☐ Métrica 2: _____ (Score: ____)
- ☐ Métrica 3: _____ (Score: ____)
- ☐ Métrica 4: _____ (Score: ____)

Presupuesto total Q1: €_____

Timeline: _____ días

Owner asignado: _____

FASE 2: Evaluar PRAGMATIC 70-84 (Baseline)

Instrucciones:

1. Métricas con score 70-84 son "YELLOW"
2. Evalúa ROI vs. cost para cada una
3. Prioriza por impacto BSIMM esperado
4. Implementa Q2-Q3
5. Presupuesto: €50k-€100k
6. Plazo: 180 días
7. Impacto: +10-15 puntos adicionales

Mis YELLOW (PRAGMATIC 70-84):

- ☐ Métrica 1: _____ (Score: ___, ROI: _____)
☐ Métrica 2: _____ (Score: ___, ROI: _____)
☐ Métrica 3: _____ (Score: ___, ROI: _____)

Presupuesto total Q2-Q3: € _____
Timeline: _____ días
Owner asignado: _____

FASE 3: Descartar o Aplazar RED (PRAGMATIC < 70)

Instrucciones:

1. Métricas con score <70 son "RED"
2. Decide: Descartar o Aplazar
3. Si descartas, busca alternativa más pragmática
4. Si aplazo, put en Q4 2026+
5. Comunica decisión a stakeholders

Mis RED (PRAGMATIC < 70):

- ☐ Métrica 1: _____ (Score: ____)
Decisión: ☐ Descartar ☐ Aplazar a Q4
Alternativa propuesta: _____
- ☐ Métrica 2: _____ (Score: ____)
Decisión: ☐ Descartar ☐ Aplazar a Q4
Alternativa propuesta: _____

PARTE V: VALIDACIÓN CRUZADA (Checklist)

Antes de finalizar, verifica que tu GQM + PRAGMATIC es coherente:

Coherencia GQM

- [] GOAL es específico y medible (tiene target cuantitativo)
- [] QUESTIONS derivan directamente del GOAL
- [] METRICS responden directamente a cada QUESTION
- [] No hay circularidad (Q1 no depende de M1 depende de Q1)
- [] Cada METRIC tiene "fórmula" clara (no ambigua)

Pragmatismo

- [] Todas las métricas PRAGMA ≥ 70
- [] TOP 10 métricas tienen PRAGMATIC ≥ 85
- [] Presupuesto estimado es realista (<€500k anual)
- [] Timeline es factible (mínimo 90 días Q1)
- [] Propietarios asignados y comprometidos

Trazabilidad

- ☐ GOAL conecta con estrategia nacional (NIS2, etc.)
- ☐ QUESTIONS son entendibles para dirección
- ☐ METRICS son medibles con herramientas existentes o factibles
- ☐ Existe baseline (medición actual)
- ☐ Existe target (medición esperada en 12 meses)

Alineación Stakeholders

- ☐ CISO comprende y aprueba
- ☐ Dirección aprobó presupuesto
- ☐ Equipos técnicos comprenden sus responsabilidades
- ☐ CFO confirmó partidas presupuestarias
- ☐ Auditoría/Compliance validó alineación regulatoria

PARTE VI: DASHBOARD DE SEGUIMIENTO

Template: Seguimiento Trimestral

TRIMESTRE: Q1 2026 (Enero-Marzo)

GOAL: [Tu GOAL]

TARGET FINAL: Score BSIMM _____ → _____

Métrica	Baseline	Target Q1	Actual Q1	% Progreso	On-Track?
M1.1	_____	_____	_____ %	☐ Sí ☐ No	
M1.2	_____	_____	_____ %	☐ Sí ☐ No	
M2.1	_____	_____	_____ %	☐ Sí ☐ No	

SCORE BSIMM: __ → __ (+__ puntos)

PRESUPUESTO Q1: €_____ (Budget: €_____, Variance: _____%)

HALLAZGOS:

- Éxito 1: _____
- Desafío 1: _____
- Acción correctiva: _____

NEXT QUARTER PRIORITIES:

- ☐ Métrica: _____ (razón: _____)
- ☐ Métrica: _____ (razón: _____)

PARTE VII: COMUNICACIÓN A DIRECCIÓN

Template: Reporte Ejecutivo Trimestral

TO: Dirección / Board

FROM: CISO

SUBJECT: Avance BSIMM + GQM + PRAGMATIC - Q1 2026

GOAL NACIONAL:

Alcanzar 70 puntos en Índice NIS2 de Madurez Ciberseguridad Software antes oct 2026

PROGRESO:

- Score anterior: 56 puntos (L2)
- Score actual: __ puntos (L2.5)
- Progreso: +__ puntos en 90 días
- Trayectoria: ☐ On-track ☐ At-risk ☐ Off-track

TOP 3 LOGROS:

1. _____ (Métrica: ____, Impacto: ____)
2. _____ (Métrica: ____, Impacto: ____)
3. _____ (Métrica: ____, Impacto: ____)

TOP 3 RIESGOS:

1. _____ (Métrica: ____, Acción: ____)
2. _____ (Métrica: ____, Acción: ____)
3. _____ (Métrica: ____, Acción: ____)

FINANCIERO:

- Presupuesto Q1: €__ (Budget: €__, Variance: __%)
- Presupuesto acumulado 2026: €__ (Budget: €__, Forecast: €__)

RECOMENDACIONES:

1. [Acción]
2. [Decisión requerida]
3. [Inversión solicitada]

SIGUIENTE MILESTONE: Q2 2026 (Abril-Junio)

Target Score: __ puntos

Target Presupuesto: €__

PARTE VIII: TROUBLESHOOTING

Problema 1: "No puedo definir GOAL claro"

Síntoma: Goal demasiado vago ("Mejorar seguridad software")

Solución GQM:

- Reemplaza con: "Reducir # de vulnerabilidades críticas en código de X a 0 en 12 meses"
- Asegúrate: Específico, medible, fecha clara, responsable

Problema 2: "Tengo muchas QUESTIONS pero pocas METRICS"

Síntoma: 5 QUESTIONS pero solo 2 METRICS

Solución QQM:

- Cada QUESTION debe tener ≥ 1 METRIC
- Si QUESTION no tiene métrica $\rightarrow$ QUESTION no es buena
- Elimina QUESTION o agrega METRIC

Problema 3: "Mi métrica tiene PRAGMATIC = 62 (RED)"

Síntoma: Score bajo, pero es importante para compliance

Solución PRAGMATIC:

- Intenta mejorar sus 9 criterios:
 - ¿Puedo hacerla más accionable? (+5 pts?)
 - ¿Puedo bajar su costo? (+8 pts?)
 - ¿Puedo obtenerla más rápido? (+7 pts?)
- Si suma < 65 aún $\rightarrow$ Considera métrica proxy más pragmática

Problema 4: "El presupuesto para mis métricas es €400k pero tengo €50k"

Síntoma: Brecha presupuestaria grande

Solución:

1. Selecciona solo PRAGMATIC ≥ 85 (TOP 10)
2. Aplaza YELLOW (70-84) a próximo año
3. Rechaza RED (< 70)
4. Recalcula: TOP 10 típicamente cuesta €15-25k Q1

Problema 5: "No tenemos datos baseline para mis métricas"

Síntoma: No sé donde estoy hoy

Solución:

1. Primera ejecución = Estimación conservadora
2. Segunda ejecución (6 meses después) = Medición real
3. Rebaseline con datos reales
4. Acepta que año 1 es "levantamiento de baseline"

PARTE IX: REFERENCIAS RÁPIDAS

Documentos Complementarios

-  Marco Integrativo: Detalle metodología QQM + PRAGMATIC
-  Matriz Pragmatic: Evaluación 50+ actividades BSIMM15
-  Resumen Ejecutivo: Hallazgos clave y recomendaciones

Herramientas Recomendadas

Para QQM:

- Excel/Google Sheets: Plantilla QQM (Parte I)
- Jira/Azure DevOps: Roadmap por QUESTION

Para PRAGMATIC:

- Excel/Google Sheets: Matriz PRAGMATIC (Parte II)
- Tableau/Power BI: Dashboard PRAGMATIC scores

Para Seguimiento:

- Google Sheets: Dashboard (Parte VI)
- Confluence/SharePoint: Reportes trimestrales (Parte VII)

CONCLUSIÓN: COMIENZO RÁPIDO

1. Hoy: Completa Parte I (GQM) - 2 horas
2. Mañana: Completa Parte II (PRAGMATIC) - 1 hora
3. Día 3: Valida Parte V (Checklist) - 30 min
4. Semana 2: Presenta a Dirección usando Parte VII - 1 h
5. Semana 3+: Implementa según Parte IV (Fases)

¡Adelante con tu transformación GQM + PRAGMATIC!

FIN DEL CUADERNO DE TRABAJO